Azure AD B2C SAML Certificate Renewal Automation

Technical Design, Business Logic, Operations, Controls, Challenges and Future Venafi Integration

Environment	Non-Production
Automation Account	EE-SRE-Automation-NonProd
Storage Account	zeneppstrp01
Blob Container	certificatepolicyrenwal
Execution	Azure Automation PowerShell 7.2
Current Storage Authentication	SAS
B2C Tenant	zelisdevb2c.onmicrosoft.com
Document Purpose	Registration / operational handoff / future enhancement baseline

Security note Secret values, SAS signatures, PFX passwords, and Graph client-secret values are intentionally not reproduced in this document. Only variable names and operational roles are documented.

Prepared as a durable reference for SRE operations, technical review, registration, troubleshooting, and the planned transition toward certificate lifecycle integration with Venafi.

1. Executive Summary

This automation monitors Azure AD B2C SAML Trust Framework policy keys, identifies certificates approaching expiration, obtains the matching replacement PFX/P12 from Azure Blob Storage, validates the certificate package, and renews the B2C policy key through Microsoft Graph. It also supports creation of a missing B2C policy key when a correctly named PFX/P12 is present in Blob Storage.

Current state	The end-to-end renewal path has been proven in Non-Prod: configuration validation, SAS access to Blob Storage, Microsoft Graph authentication, due-certificate detection, PFX validation, policy-key delete/recreate, PFX upload, and post-upload thumbprint verification.

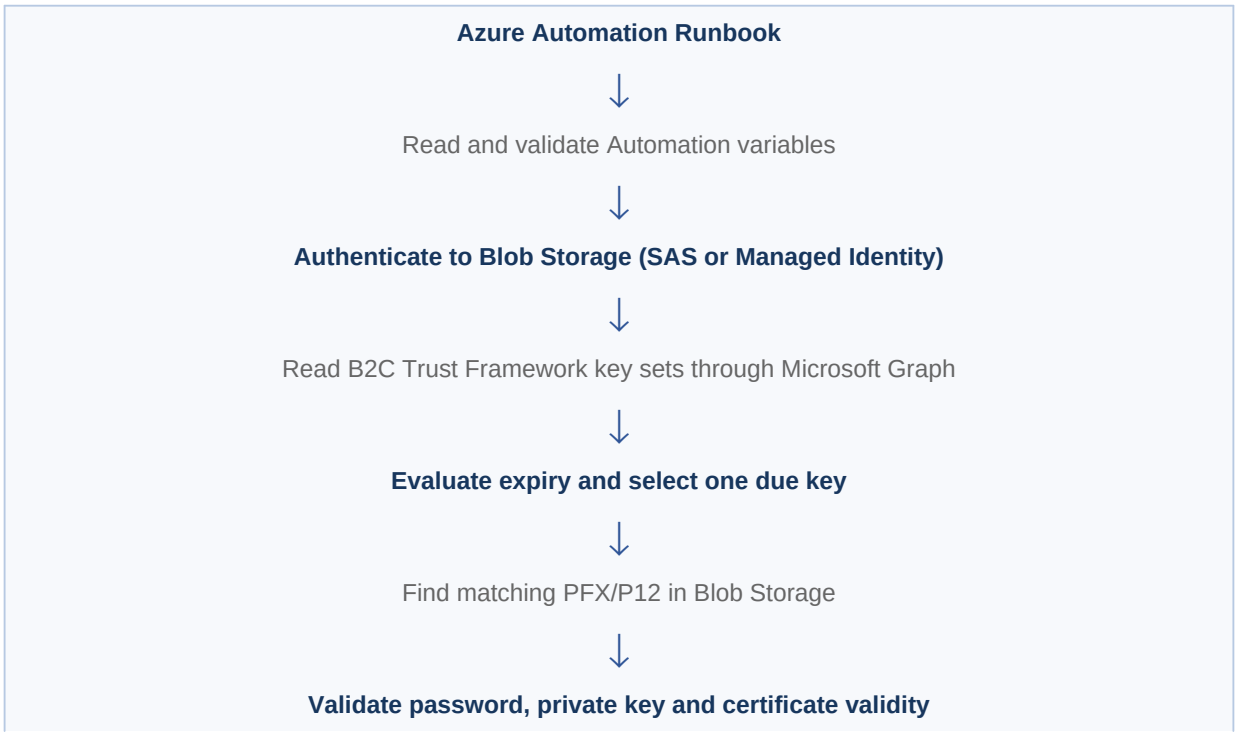
Business objective

Reduce manual certificate-expiry risk for SAML integrations while retaining explicit validation, traceable status messages, controlled blast radius, and an operational path for SRE intervention when a certificate or configuration is not ready.

Current operating model

- Azure Automation hosts and executes the PowerShell runbook.
- Microsoft Graph is used to read and modify B2C Trust Framework key sets.
- Blob Storage is the current certificate package staging location.
- SAS is the active Blob authentication method in the current Non-Prod implementation. Managed Identity remains supported by code.
- The Graph client secret and current PFX password are held in encrypted Azure Automation variables.
- Email delivery is currently disabled; job output and optional HTML reporting provide operational status.

2. Architecture and Component Responsibilities



↓

DryRun: report only | Real run: delete/recreate/upload/verify

↓

Aligned operational report with before/after values

Component	Responsibility
Azure Automation Account	Runs the PowerShell 7.2 runbook, stores configuration and encrypted secrets, captures job history/output.
Microsoft Graph	Reads B2C Trust Framework key sets; creates/deletes key sets; uploads PKCS#12; verifies the uploaded certificate.
Azure Blob Storage	Stages replacement PFX/P12 certificate files using policy-key-based filenames.
SAS / Managed Identity	Provides Blob data-plane authentication. Current configuration uses SAS.
B2C Trust Framework Key Sets	Stores SAML signing/federation certificate material used by B2C custom policies.
SRE Team	Provides/validates certificate packages and passwords, stages them correctly, reviews blocked/urgent results, and operates approved production changes.
Future Venafi Integration	Target source for centrally managed certificate issuance/renewal and password/secret workflow, reducing manual PFX staging.

3. Current Configuration Model

The runbook reads Azure Automation variables first and validates configuration before performing certificate operations. Required variables that are missing, malformed, or inconsistent stop the run with an actionable configuration error. The code supports SAS and Managed Identity for Blob access. ■filecite■turn11file0■L96-L134■

Variable	Purpose	Current / expected
B2CRenew_TenantId	B2C tenant GUID	Configured; valid GUID required
B2CRenew_ClientId	App registration client ID	Configured; valid GUID required
B2C-SAML-RENEWAL-CLIENT-SECRET	Microsoft Graph client secret	Encrypted Automation variable
B2CRenew_StorageAuthMode	Blob authentication selector	SAS (ManagedIdentity also supported)
B2CRenew_BlobContainerUrl	Certificate staging container	https://zeneppstrp01.blob.core.windows.net/certificatepolicyrenwal
B2CRenew_BlobContainerSasUrl	Container SAS URL	Configured; secret/signature must not be documented
certificatepolicyrenwalpaswword	PFX/P12 password	Encrypted; optional empty value supported
B2CRenew_RenewBeforeDays	Normal renewal window	30 days
B2CRenew_WarningDays	Warning threshold	90 days

Variable	Purpose	Current / expected
B2CRenew_FreezeMonths	Special renewal months	11,12,1
B2CRenew_FreezeRenewMonth	Special early-renewal month	10
B2CRenew_PolicyKeyNameFilter	Key filtering	saml
B2CRenew_DryRun	Safety control	true = validate only; false = real changes
B2CRenew_TimeZone	Reporting timezone	Eastern Standard Time
B2CRenew_EmailMethod	Report delivery	None currently

Important The current code reads the Graph secret directly from B2C-SAML-RENEWAL-CLIENT-SECRET and the PFX password directly from certificatepolicyrenwalpaswword. Key Vault is not currently accessed by the runbook.

4. Certificate Naming and Matching Rules

The certificate file name is the operational join between Blob Storage and the B2C policy key. For an existing key, the runbook accepts either the full policy-key name or the short name with .pfx or .p12. For automatic creation of a missing policy key, the Blob filename must follow the B2C_1A_*.pfx or B2C_1A_*.p12 pattern.

Examples

Existing policy key: **B2C_1A_b2csamltestsigning**
Preferred Blob file: **B2C_1A_b2csamltestsigning.pfx**
A new Blob file such as **B2C_1A_NewPartnerSAML.pfx** can become a new B2C policy key named **B2C_1A_NewPartnerSAML** when no existing key has that ID.

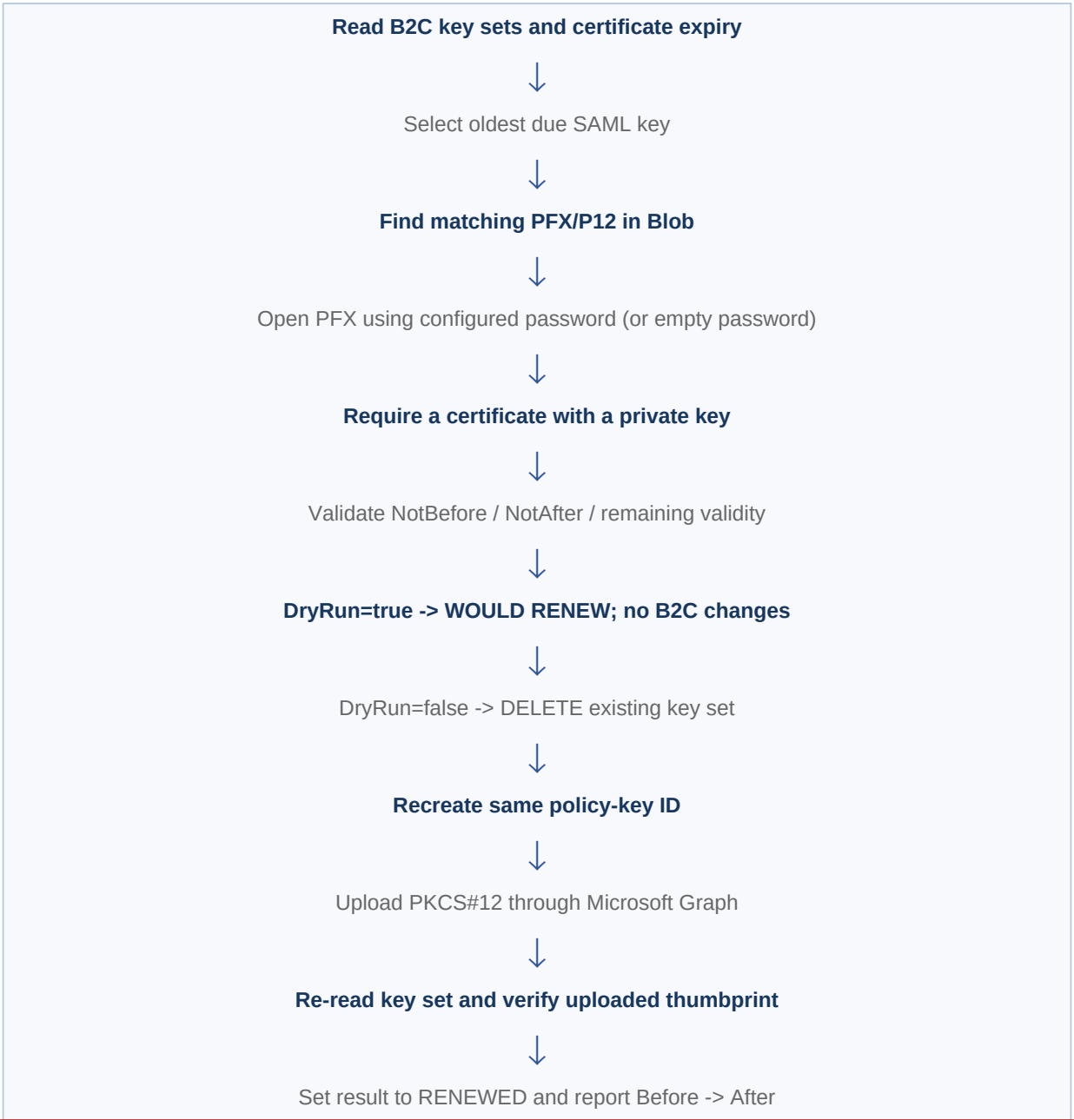
Current password limitation The current design uses one Automation variable for the PFX password. That works when staged PFX files share the configured password, but it does not scale cleanly when each certificate has a different password. This is a key reason for the planned Venafi/secret-management enhancement.

5. Business Logic - Monitoring and Renewal Eligibility

Rule	Behavior
Expired	Days left < 0 -> Expired
Critical	Days left <= 30 -> Critical
Warning	Days left <= 90 -> Warning
Normal renewal start	30 days before expiry
Freeze-window rule	Certificates expiring in Nov/Dec/Jan become eligible beginning October 1
Processing order	Oldest-expiring due key first
Blast-radius control	Only one existing due key is processed per run
New-key creation priority	A missing policy key is considered only when no existing renewal candidate is processed
Replacement comparison	Old/new thumbprints are intentionally NOT compared

Rule	Behavior
Replacement validity	PFX must open, contain a private key, be valid now, not be expired, and have > RenewBeforeDays remaining

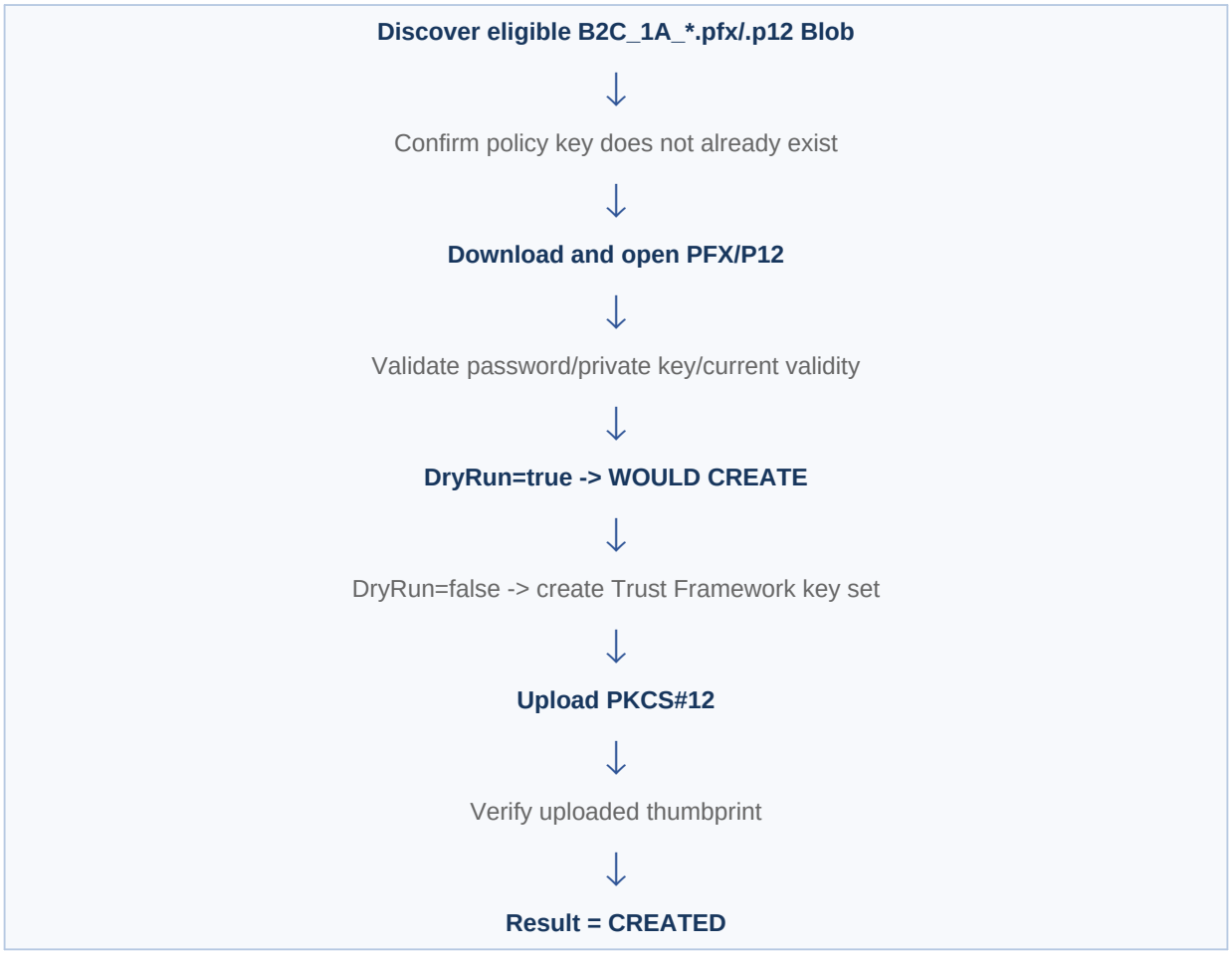
6. Existing Policy-Key Renewal Flow



Destructive step	The real renewal path deletes the existing key set before recreating it. If recreation, upload, or verification fails after deletion, the runbook marks the result as urgent manual action. This is why DryRun and pre-validation are important controls.

7. New Policy-Key Creation Flow

When no existing renewal is due, the runbook scans Blob Storage for a file named B2C_1A_*.pfx or B2C_1A_*.p12 whose policy-key ID does not already exist. It processes at most one missing key per run.



8. Validation and Error Handling

The runbook is designed so the job output explains the problem, affected policy key/file, required action, and technical error where available. Secret values are not printed.

Status / error	Meaning	Operational action
CONFIG ERROR - REQUIRED VARIABLE MISSING	Required Automation variable is absent/empty	Create or correct the named variable and rerun
CONFIG ERROR - INVALID TENANT/CLIENT ID	GUID format is invalid	Correct tenant/client configuration
CONFIG ERROR - INVALID STORAGE AUTH MODE	Mode is not SAS or ManagedIdentity	Set supported value
CONFIG ERROR - SAS TARGET MISMATCH	SAS URL points to a different account/container	Generate SAS for configured container
BLOB ACCESS FAILED	Container cannot be listed/downloaded	Check SAS/RBAC, expiry, permissions, networking/firewall
PFX NOT FOUND	No expected PFX/P12 exists	Upload correctly named replacement file
PFX PASSWORD OR FILE INVALID	PFX cannot be opened	Validate file and encrypted password variable
PRIVATE KEY MISSING	PFX contains no usable private key	Export/upload PFX with private key

Status / error	Meaning	Operational action
PFX CERTIFICATE EXPIRED	Replacement is already expired	Provide a current certificate
PFX VALIDITY TOO SHORT	Replacement has <= renewal threshold remaining	Provide longer-validity certificate
PFX NOT YET VALID	NotBefore is in the future	Use a currently valid certificate or wait
ERROR - CREATE FAILED	Graph could not create key set	Check Graph permissions/admin consent and duplicate state
URGENT - NEW KEY CREATED BUT PFX UPLOAD FAILED	Empty/new key may exist without cert	Upload manually or safely remove unused key
ERROR - VERIFY FAILED	Graph did not confirm expected uploaded certificate	Verify key manually before use
FAILED - URGENT MANUAL ACTION	Existing key was deleted but recreate/upload/verify failed	Immediate manual recovery and dependent-policy validation

9. Reporting and Operational Evidence

The console and HTML report distinguish pre-change and post-change values so a successful renewal no longer appears as Critical with the old expiry. A real renewal changes the row status to OK and retains the previous values for audit context.

Field	Purpose
Before Expiry / Before Days	Snapshot that triggered the renewal
After Expiry / After Days	Validated replacement certificate values
Renew From	Calculated eligibility date
Action	RENEWED, CREATED, DRY RUN, MONITOR, blocked, error, or urgent
Details	Short explanation, file, old/new values, required action, technical error where relevant
Color semantics	Green success; blue DryRun; yellow monitor; orange action required; red failure/urgent

Example - successful renewal

Status: OK **Policy:** B2C_1A_b2csamltestsigning
Before: 2026-10-30 / 3 days **After:** 2032-10-22 / long-term validity
Action: RENEWED
Verification: Uploaded certificate thumbprint confirmed by Microsoft Graph.

10. Challenges Encountered and Resolution

Challenge	Observed behavior	Resolution / learning
Storage network restriction	Initial Blob requests returned HTTP 403 even when authentication context was created	Authentication and network authorization are separate. A valid identity/SAS does not override Storage firewall/network rules.

Challenge	Observed behavior	Resolution / learning
Managed Identity vs SAS	Both approaches were investigated; Managed Identity context creation did not by itself solve restricted Blob access	Current working Non-Prod path uses a SAS against the selected Storage account/container. Code retains both modes.
Wrong Storage target during testing	SAS URL and normal Blob URL temporarily pointed to different storage accounts/containers	Added SAS target validation so account/container mismatch fails before certificate processing.
Same/short-lived test PFX	An early PFX had only a few days remaining and was rejected	Validation correctly required sufficient remaining validity; a longer-validity PFX passed.
Old values displayed after renewal	Table showed old expiry/days beside RENEWED	Reporting enhanced to display Before and After expiry/days and set successful real renewal status to OK.
Single shared PFX password	Current variable model assumes one configured password at a time	Future design should map each certificate to its own secret/password or obtain it from Venafi/approved secret storage.

11. SRE Operating Procedure - Current State

- Obtain the approved replacement PFX/P12 containing the private key.
- Confirm the intended B2C policy-key ID and use the matching filename, preferably B2C_1A_.pfx.
- Upload the PFX/P12 to the configured Blob container.
- Ensure the encrypted PFX-password Automation variable contains the password for the certificate being processed; do not place the password in logs, tickets, or filenames.
- Run with DryRun=true first. Confirm the output says DRY RUN - WOULD RENEW or DRY RUN - WOULD CREATE and review proposed expiry/days.
- For an approved real change, set/execute with DryRun=false.
- Confirm RENEWED or CREATED, verify the After Expiry/After Days values, and confirm Microsoft Graph verification succeeded.
- If the result is SRE ACTION REQUIRED, correct the stated file/password/validity/configuration issue and rerun.
- If the result is FAILED/ERROR/URGENT after a destructive operation, follow immediate manual recovery guidance before dependent B2C policies are used.

Do not automate blindly	Because the real existing-key renewal performs DELETE -> CREATE -> UPLOAD -> VERIFY, production scheduling should include change controls, reliable certificate sourcing, secret handling, and an agreed recovery procedure.

12. Security and Control Considerations

- Do not store SAS URLs containing signatures in documentation or tickets. Rotate exposed SAS credentials.
- Prefer encrypted Automation variables or approved secret-management integration for secrets.
- Do not log the Graph client secret or PFX password.
- Use HTTPS-only SAS and least-privilege Blob permissions required by the runbook.
- Use short SAS lifetimes where operationally feasible and establish a renewal/rotation process for the SAS itself.

- Maintain Microsoft Graph permissions at the minimum level required for Trust Framework key-set operations and monitor app-secret expiration.
- DryRun should remain the standard validation mode for onboarding a new certificate or changing configuration.
- Only one existing due key per run limits blast radius; retain this control unless a reviewed batch design replaces it.

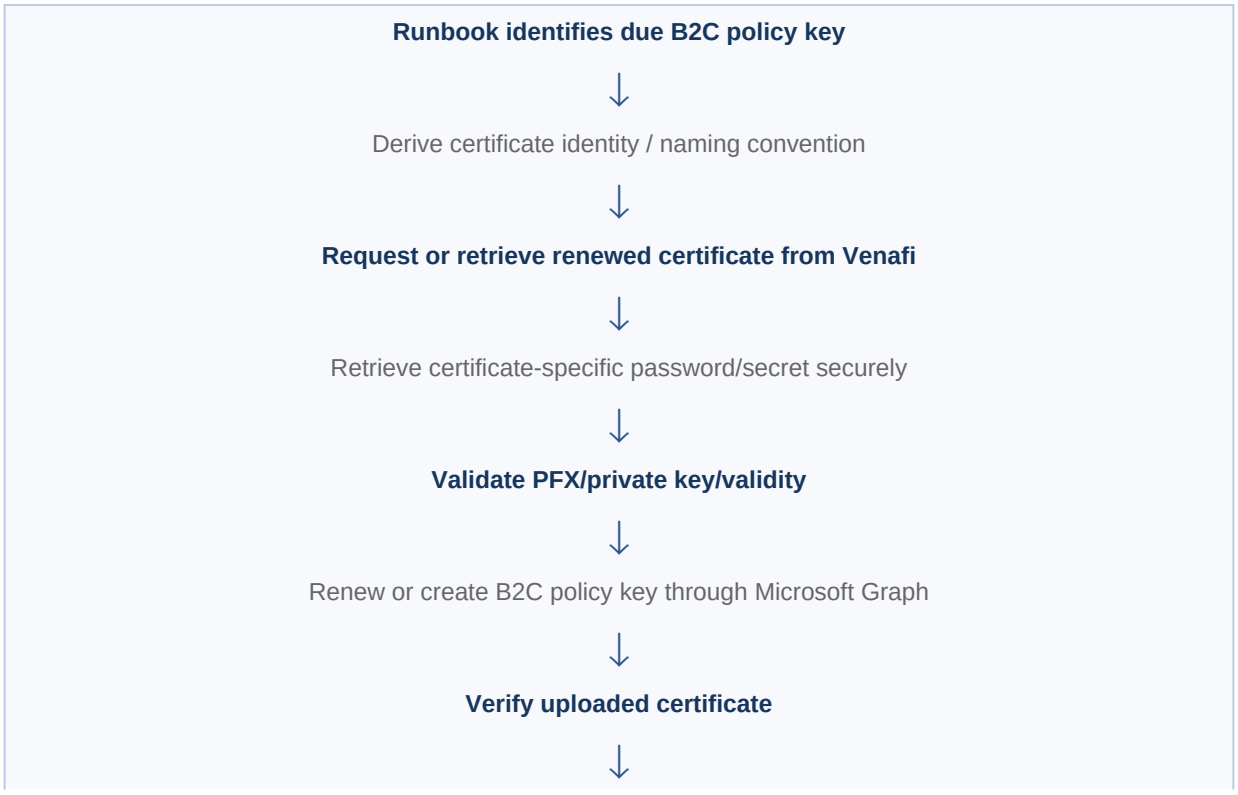
13. Current Limitations

- The runbook currently uses a single PFX-password variable, so multiple certificates with different passwords cannot all be processed unattended with the current password model.
- Certificate acquisition is external to this runbook; SRE must currently obtain and stage the PFX/P12.
- The current secret approach uses encrypted Automation variables rather than Key Vault in the code path.
- Email is disabled in the current configuration.
- SAS has an expiry and therefore introduces an operational dependency that must be rotated before expiration.
- Existing-key renewal uses delete/recreate rather than an in-place certificate swap; failure after deletion requires urgent recovery.
- The new-key creation path only runs when no existing renewal candidate is processed and creates at most one missing key per run.

14. Future State - Venafi Integration

The strategic enhancement is to integrate certificate lifecycle management with Venafi so the automation can obtain the approved certificate package and associated secret material through a governed workflow rather than relying on manual PFX upload and one shared password variable.

Target future flow



Record status and audit evidence

Recommended Venafi design requirements

- Define a deterministic mapping between B2C policy-key ID and Venafi certificate object/application.
- Support a unique password/secret per PFX rather than a single global password.
- Return certificate and password through authenticated APIs or an approved secret broker; never expose them in logs.
- Define issuance/renewal ownership, certificate template, key algorithm/size, validity period, subject/SAN requirements, and approval workflow.
- Decide whether Blob remains a staging/audit layer or Venafi becomes the direct source consumed by the runbook.
- Add certificate retrieval retries, Venafi-specific error messages, and correlation/audit identifiers.
- Preserve DryRun and one-at-a-time processing for controlled rollout.
- Add lifecycle handling for Venafi/API credentials and Microsoft Graph app credentials.

15. Proposed Future Password Mapping

The current single password variable should evolve into certificate-specific secret resolution. A simple conceptual model is shown below; the actual implementation should use the approved enterprise secret/Venafi integration rather than storing plaintext mappings.

Policy key	Certificate source	Password source
B2C_1A_PartnerA	Venafi object / application A	Certificate-specific secret A
B2C_1A_PartnerB	Venafi object / application B	Certificate-specific secret B
B2C_1A_PartnerC	Venafi object / application C	Certificate-specific secret C

Goal Remove the need for SRE to manually update one shared PFX password before each differently protected certificate is processed.

16. Registration / Handoff Checklist

Area	Registration / review item
Ownership	Confirm service owner, SRE operational owner, escalation contact, and B2C application owner.
Runbook	Register source-controlled PowerShell and deployment/update procedure.
Identity	Register Graph app/client ID, permissions, admin consent owner, and client-secret rotation.
Storage	Register Storage account/container, network controls, SAS rotation owner, and least-privilege permissions.
Secrets	Document variable names only; register approved secret storage/rotation process.
Certificates	Define naming convention, source, validity standard, private-key requirement, and password ownership.
Scheduling	Define run frequency and change window expectations.

Area	Registration / review item
Monitoring	Define alert route for Critical, SRE ACTION REQUIRED, ERROR, FAILED, and URGENT.
Recovery	Document manual B2C key recreation/upload procedure for destructive-path failure.
Venafi roadmap	Register future integration dependency, API/access requirements, certificate mapping, and password-per-certificate model.

17. Verification Evidence from the Non-Prod Test

The validated real-run sequence completed configuration validation, SAS Blob context creation, Microsoft Graph token acquisition, detection of the due policy key, deletion/recreation, PFX upload, and post-upload verification. The renewed B2C key reported the new certificate thumbprint and a new expiry in 2032. This demonstrates the functional end-to-end path in the current Non-Prod environment.

Verified outcome	The renewed B2C policy key B2C_1A_b2csamltestsigning was verified after upload with the replacement certificate. The improved report retains the old expiry as Before and presents the replacement expiry as After.

18. Recommended Next Steps

- Place the finalized runbook in source control and use a reviewed promotion/deployment process.
- Keep DryRun as the default for onboarding and configuration changes.
- Define a SAS rotation mechanism or move Blob authentication to an approved identity/network design when available.
- Replace the single shared PFX-password model with certificate-specific secret resolution.
- Design and implement Venafi integration for certificate retrieval/renewal and password handling.
- Enable an approved notification path so blocked/urgent outcomes reach SRE without relying only on job inspection.
- Create a documented manual recovery runbook for the delete/recreate failure window.
- Perform production readiness review covering permissions, network controls, secret rotation, scheduling, monitoring, rollback/recovery, and ownership.

Appendix A - Status and Color Legend

Status	Color	Meaning
RENEWED / CREATED	Green	Successful real change
DRY RUN - WOULD RENEW / CREATE	Blue	Validation succeeded; no B2C change
MONITOR	Yellow	Approaching renewal eligibility
SRE ACTION REQUIRED / NOT PROCESSED	Orange	Human action or prerequisite required
ERROR / FAILED / URGENT	Red	Technical failure or immediate recovery required

Appendix B - Key Code Behaviors

The current runbook validates required configuration before operations; supports SAS or Managed Identity for Blob access; validates the PFX and private key; intentionally does not compare old/new thumbprints; uses DryRun as a safety barrier; verifies the uploaded thumbprint through Microsoft Graph; and limits processing to one existing due key per run. ■filecite■turn11file0■L18-L30■